GOVERNANCE · RISK · COMPLIANCE

Findings Key

The 46 planted findings in the Norvela Pay estate, with the framework and regulatory linkage for each.

COMPANION TO	The Norvela GRC Lab Manual
OPEN AFTER	Phase 3 (control assessment)
FINDINGS	46, across seven domains
AUTHOR	Bilal Ahmad Kamal

> **Sealed supplement.** The lab is only worth doing if you find these yourself. Do not read this until you have completed your own assessment through Phase 3.

Norvela Pay, its people, its vendors, its licence number, its incident and its supervisory correspondence are entirely fictional. Real tools and real regulations are named accurately; the company they are applied to is not real. Regulatory dates were current as of September 2026. Verify before citing.

Findings Key

Seriously. The value of this lab is in finding these yourself. Reading this first converts a training exercise into an article.

Do Phases 1–3 first. Then come back and see what you missed. Missing things is normal and is the actual lesson: a first-pass assessment always misses some, which is why review, a second pair of eyes, and structured checklists exist.

Scoring yourself

Found	Verdict
35+	Better than most people doing this job
25–34	Solid. You're interview-ready on assessment technique.
15–24	Normal first pass. Work out *why* you missed the ones you missed — method gap or knowledge gap?
<15	Redo the assessment with a structured checklist rather than reading and reacting.

Identity and access (8)

1. **Two leavers retain live AWS IAM credentials** (r.tavares, l.moreira). Entra was disabled; IAM was not. Root cause: leaver process covers only SSO-integrated systems. *ISO A.5.18, A.8.2 · DORA Art. 9 · SOC 2 CC6.2*
2. **Shared break-glass account** `prod-admin` assumable by 11 people, used 43 times last quarter, no session recording. No individual accountability.
3. **Shared contractor account** (`contractor-nocturne-01`) used by rotating agency staff in the Poland NOC, with break-glass privileges and no MFA.
4. **Two AWS root accounts without MFA** (`sandbox`, `dev`). Sandbox root credential holder is unknown — that is an unowned crown-jewel credential.
5. **Dormant service account with AdministratorAccess** (`svc-legacy-etl`), unused for 2.5 years, key 1,800 days old.
6. `svc-settlement-batch` **key not rotated since 2023** — the breach vector. No service-account rotation policy exists at all.
7. **External auditor account with no expiry date.**
8. **60 engineers hold PowerUserAccess in** `norvela-dev` with no periodic recertification.

Data protection (7)

9. **Unmasked production data in staging** — Nov-2025 restore with live PANs and customer names, readable by 60 developers. This is simultaneously a GDPR Art. 5(1)(c) and 32 failure, a PCI DSS scope explosion, and an ISO A.8.11 (data masking) gap. *Your headline finding.*
10. **Fraud scoring under "legitimate interest"** — arguably wrong basis given automated decisions that auto-decline transactions under €500 with no human review. Consider Art. 22 automated decision-making instead, which brings its own safeguards.
11. **Call recordings under "consent"** but no consent is collected on inbound calls. Basis fails at the first question.

12. **Talkdesk is US-hosted** with no documented transfer mechanism, no TIA.
13. **Onfido processes biometric facial data** — Art. 9 special category — with the sub-processor chain unmapped, and a post-Brexit UK transfer whose legal basis is undocumented.
14. **Retention policy not implemented.** Policy says 7 years; practice is "never delete." Data lake holds 2019 records; recordings kept indefinitely. *GDPR Art. 5(1)(e).*
15. **RoPA 14 months stale and missing Snowflake and Personio.** *Art. 30 — and an incomplete RoPA is often the first thing a DPA asks for.*

Third party (6)

16. **Sertã Systems** — two-person company with standing VPN to the authoritative Ledger, 2019 contract, no DORA clauses, no audit rights, no exit plan, never reviewed, key-person risk. The worst single exposure.
17. **Snowflake is shadow IT** — procured on a data-team card, holds full transaction history and PII, no vendor review, no DPA.
18. **Personio unknown to Lisbon IT** — which is the root cause of finding 1.
19. **AWS concentration at 100%** of production with no tested exit plan.
20. **Okta still in the register** two years after termination — register hygiene, and it means the register cannot be trusted as a control.
21. **Datadog holds PANs in logs**, three confirmed cases, unremediated — pulls an observability vendor into PCI scope.

Technical controls (9)

22. **No network segmentation** between corporate VLANs and the Lisbon server room. The HSM cluster is reachable from any office network.
23. **ESXi hosts end-of-support since 2024**, still in production.
24. **15 unmanaged Linux workstations** in the Poland NOC with production access — no EDR, no patching, not in any inventory.
25. **Application log retention 14 days** for the Vault service, which directly prevented establishing the breach start date.
26. **38 critical vulnerabilities older than 180 days**, no documented SLA.
27. **Six known-leaked secrets unrotated** after the 2025 scan; the ticket was closed as "won't fix — scheduled for decom" and the decom never happened. *The closure was done by the team that owned the risk — no independent verification of remediation.*
28. **Repository public for 11 days in March 2024** with no alerting on org visibility change, and no retrospective assessment of what was exposed.
29. **No egress filtering from production** — the data lake exfiltration had no network control in its path.
30. **Ledger restore never successfully tested**; last attempt 2022, failed. The documented RTO is therefore fiction.

Governance (8)

31. **CISO role vacant, Head of Platform Engineering acting** — first line policing itself. *DORA Art. 5 governance, ISO Clause 5.3.*

32. **Part-time DPO who is also company secretary** — potential Art. 38(6) conflict, and 0.5 FTE for a firm processing 40M transactions/yr.
33. **Risk Committee met 3 times in 18 months**, charter from 2022 never amended.
34. **No Change Advisory Board**; changes approved in the pull request, with no separation between author and approver for payment-path changes.
35. **No ICT internal audit ever performed.** Internal Audit is 1 FTE at 80% AML.
36. **Board only added cybersecurity as a standing item in March 2026**, and only in response to a supervisory letter. *Under NIS2/RJC, management bodies carry direct liability — this is evidentially weak.*
37. **No BIA has ever been performed**, so RTO/RPO figures throughout the estate are unsourced.
38. **Policies not reviewed** — InfoSec Policy v2.1 from 2023; AUP signed by 61% of staff; access control policy describes a JML process HR does not follow.

Process and training (4)

39. **Poland NOC excluded from awareness training** because their HR system is separate — 74% completion is therefore also overstated relative to the real population.
40. **No escalation criterion for unexplained anomalies** — the on-call engineer restarted a failing service at 03:14 and raised no ticket because no rule said he should.
41. **Incident Response Plan v1.0 (2022)** does not reference DORA or NIS2 timelines and has never been exercised.
42. **BCP covers the Lisbon office only** (fire/flood). Nothing for cloud outage — which is the only scenario that has ever actually threatened the service.

AI governance (4)

43. **Sentinel retrained monthly on production data** with no approval gate, no model card, no bias testing, no documented performance monitoring.
44. **Auto-decline below €500 with no human review path** — consider GDPR Art. 22 and, for AI Act purposes, whether meaningful human oversight exists.
45. **Flow's AI Act classification unresolved** — creditworthiness assessment is an Annex III use case, and the provider/deployer split with Banco Astera has never been documented in the contract.
46. **No AI inventory** exists. Neither model appears in any asset register with an AI-specific classification.

The meta-lesson

Count how many of these are *technology* failures and how many are *organisational* failures. It's roughly 40/60 in favour of organisational — separate HR systems, a closed ticket nobody verified, a committee that doesn't meet, a role nobody owns.

That ratio is why GRC exists as a discipline, and why technical security experience needs this layer on top of it to convert into a senior role. The technical findings a practitioner can already spot. The organisational ones are what this lab is actually teaching you to see.